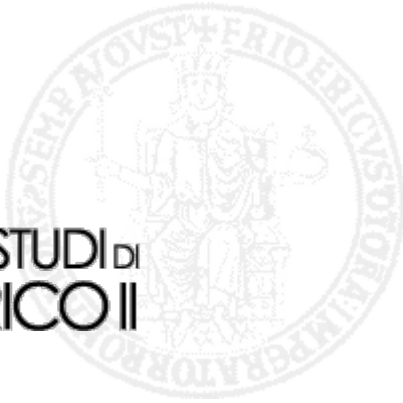


UNIVERSITA' DEGLI STUDI DI
NAPOLI FEDERICO II



Software Security

Supply-Chain Attack against

Notepad++: Analysis of Chrysalis

De Lucia Simone M63001720
Covone Gabriel M63001809

Indice

1	Analisi Malware Chrysalis	1
1.1	Descrizione	1
1.1.1	Chrysalis	2
1.2	Analisi	2
1.2.1	Tool Utilizzati	2
1.3	Esecuzione del malware e Indicatori di Compromissione (IoC) . . .	3
1.3.1	File creati nell'host	3
1.3.2	Connessioni all'esterno e Traffico C2	7
1.4	Roadmap di Analisi Operativa	14
1.4.1	Analisi di Dettaglio dei Componenti e Ingegneria Inversa . .	16
1.4.2	Estrazione e Analisi Dinamica dello Shellcode	19
1.4.3	Architettura del Modulo Principale (Chrysalis Backdoor) . .	26



Capitolo 1

Analisi Malware Chrysalis

Studenti

- De Lucia Simone M63001720
- Covone Gabriel M63001809

1.1 Descrizione

Nel febbraio 2026 il gruppo di ricerca di Rapid7 fa luce su una campagna malware attribuita al gruppo APT Lotus Blossom che coinvolge il meccanismo di update automatici dell'applicazione di note Notepad++, rivelandosi di fatto un attacco supply chain. In particolare, la campagna ha avuto vari step tra cui:

- la compromissione dei sistemi di rilascio degli update, accedendo in maniera non autorizzata ai sistemi di rilascio degli update.
- dirottare selettivamente alcuni traffici verso la risorsa mediante file manifest XML customizzati, costringendo così a forzare il software degli update automatici usato da Notepad++, in questo caso WinGUp.
- installare su target specifici dei pacchetti compromessi, sfruttando l'assenza di meccanismi di controllo dell'integrità crittografica nelle versioni del client WinGUp precedenti alla 8.8.9.

La campagna malware ha avuto una finestra temporale di circa 5 mesi, dal settembre 2025 al gennaio 2026; le vittime si concentravano in organizzazioni governative, istituzioni finanziarie e fornitori di servizi IT. In particolare, sono state colpite:

- Un'organizzazione governativa nelle Filippine.
- Un fornitore di servizi IT in Vietnam.
- Un'istituzione finanziaria in El Salvador.



- Singoli utenti tecnici localizzati in Vietnam, Australia ed El Salvador.

Durante questo periodo, il malware ha operato in maniera silenziosa in tutti i sistemi infetti, effettuando information gathering e ottenendo accessi a sistemi critici in maniera remota. Inoltre, sono state trovate varie tipologie di loader e di servizi URL legati all'attacco in sé.

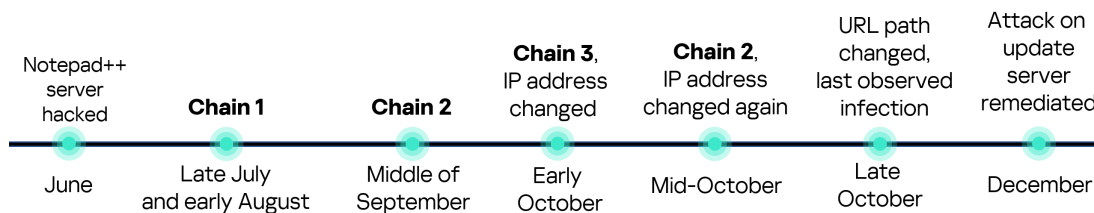


Figura 1.1: Monitoraggio campagna giugno/dicembre

1.1.1 Chrysalis

Durante questa campagna, l'ultimo malware utilizzato è stato rinominato Chrysalis. La sua caratteristica principale risiede nel meccanismo di persistenza e di sofisticatezza del tool, oltre che a tanti strumenti di offuscamento. Dal punto di vista delle analisi, il malware è stato visto come uno step in avanti rispetto alle capacità pregresse del gruppo APT Lotus Blossom, e il chiaro intento di usare il malware per gestire una rete di informazioni da host infetti con uno strumento avanzato.

1.2 Analisi

Chrysalis è un malware backdoor che viene distribuito tramite un installer NSIS compromesso (`update.exe`), ottenuto grazie alla compromissione di WinGUp e alla catena di approvvigionamento degli update automatici.

1.2.1 Tool Utilizzati

I tool utilizzati sono suddivisi in base alla fase operativa per intercettare, decodificare e sconfiggere i meccanismi di evasione del malware:



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Fase	Strumenti	Scopo
1. Triage e Analisi Statica	PEstudio, PEview, capa	Ispezione dell'entry point iniziale
2. Monitoraggio e Simulazione	Procmon, FakeNet-NG, Wireshark	Monitoraggio del comportamento di simulazione C2.
3. Debugging e Memory Dumping	x32dbg, ScyllaHide, Scylla, PE-bear	Esecuzione e evasione del dumping della IA7
4. Reverse Engineering e IoC	IDA Freeware 8.2, FLOSS, yarGen	Decompilazione logica e offuscamento delle stringhe

Tabella 1.1: Fasi operative e strumenti utilizzati durante l'analisi.

1.3 Esecuzione del malware e Indicatori di Compromissione (IoC)

Il primo step è stato fatto per raccogliere informazioni relative al malware, sia dal punto di vista di report online e di analisi, sia come opera all'interno di un sistema infetto. Questo non solo ci permette di consolidare le informazioni lette, ma anche di approfondire vari aspetti dell'infezione.

Si è partiti con l'esecuzione dell'update malevolo, per poi analizzare il comportamento scaturito all'interno dell'host.

1.3.1 File creati nell'host

Una volta avviato l'update malevolo, all'interno del disco di sistema viene creata la cartella %appdata%\Roaming\Bluetooth\ contenente i vari file malevoli che andranno a costituire la catena di esecuzione del malware.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

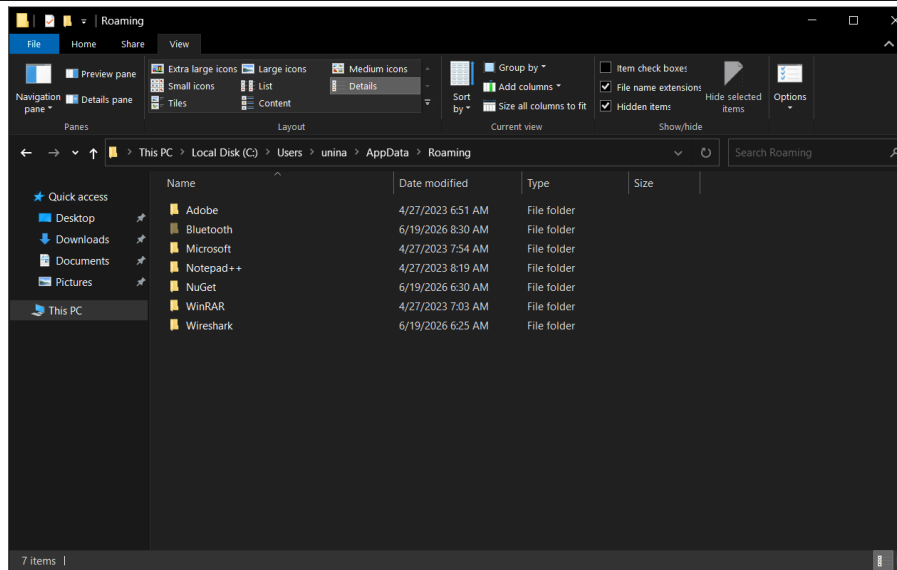


Figura 1.2: Cartella AppData Roaming

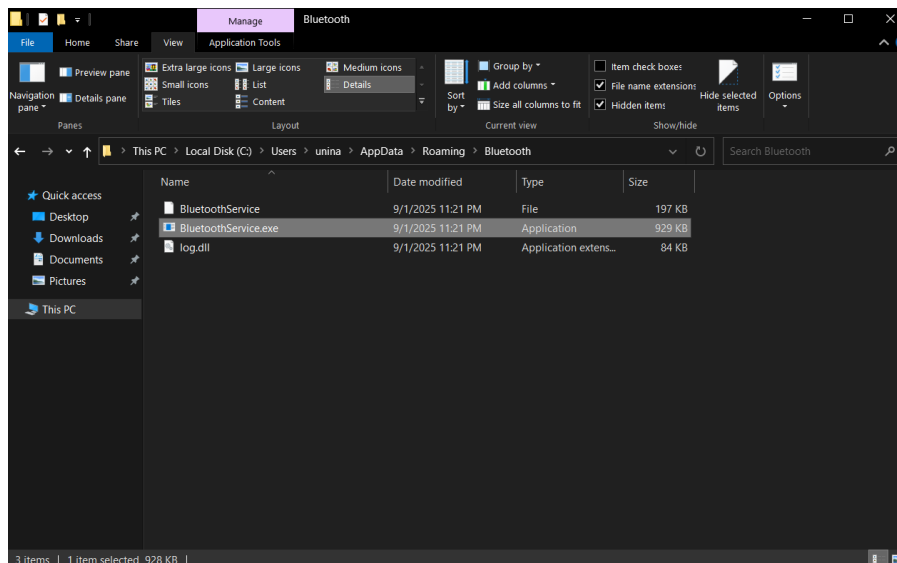


Figura 1.3: Contenuto Cartella Bluetooth

Vengono identificati tre file, di cui ne analizziamo l'entropia e le proprietà:

- **BluetoothService.exe**: L'eseguibile in sé è legittimo, tuttavia possiamo notare che la firma è stata modificata. In realtà risulta essere un servizio BitDefender. Eventuali ricerche hanno portato alla luce che normalmente può effettuare side-loading di una libreria di logging.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

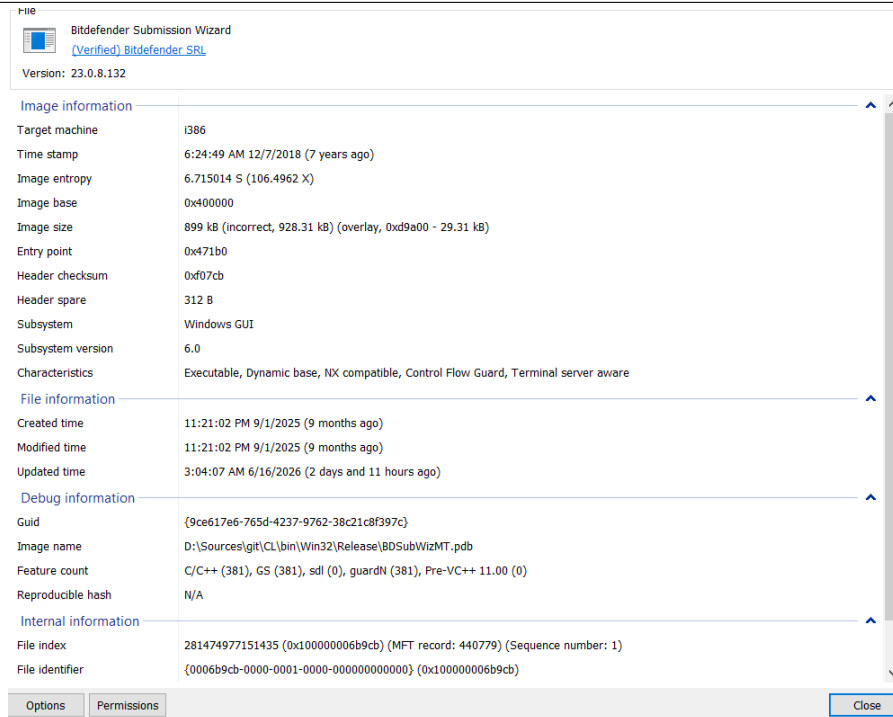


Figura 1.4: Proprietà di BluetoothService.exe

- **log.dll**: La libreria appare legittima, tuttavia viene notata un'entropia abbastanza elevata nella sezione di testo, simbolo che ci sia del codice cifrato.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

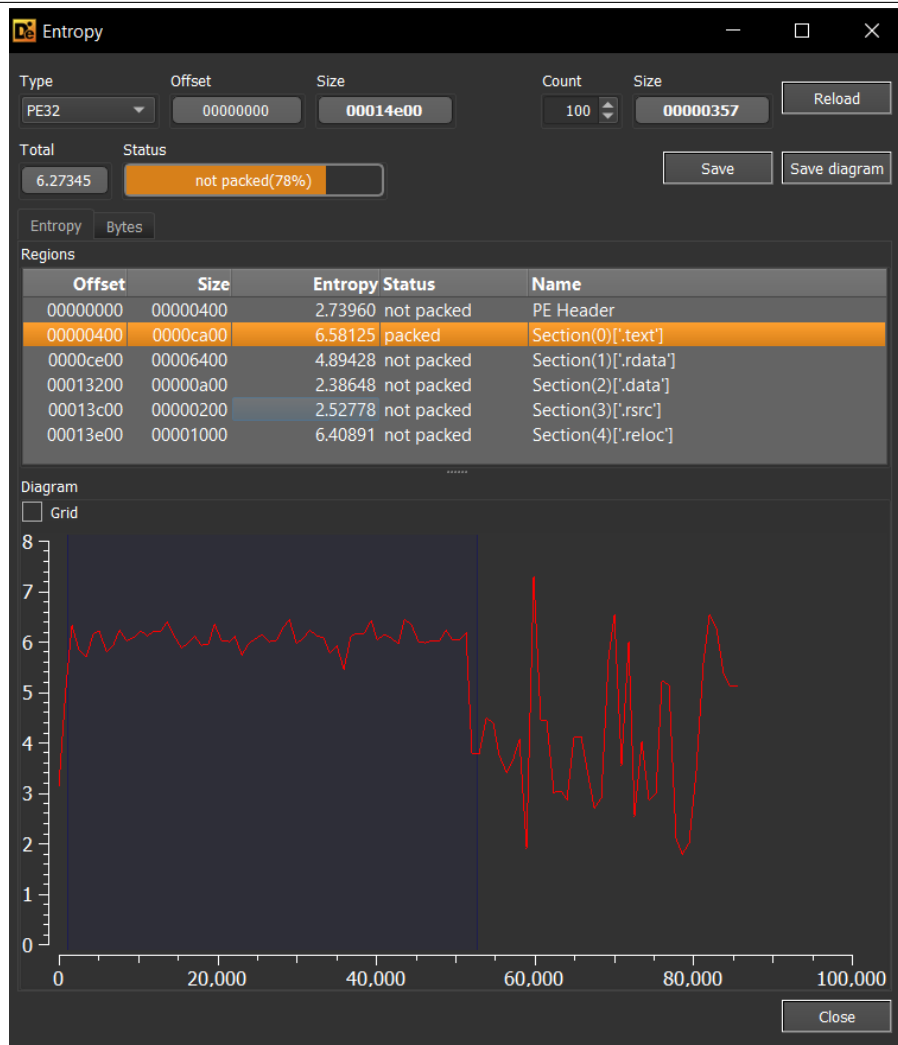


Figura 1.5: Entropia DLL

- **BluetoothService:** Il file è cifrato ed è senza estensione, è lo shellcode vero e proprio.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

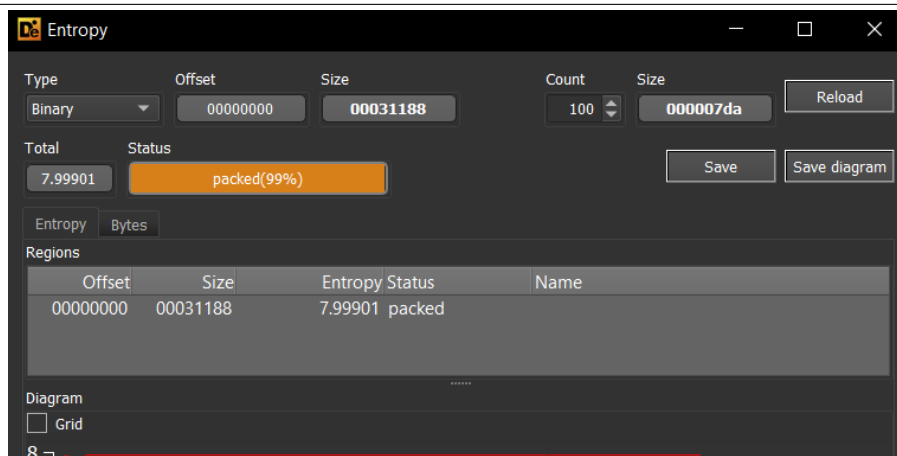


Figura 1.6: Entropia ShellCode

1.3.2 Connessioni all'esterno e Traffico C2

Un altro passaggio è stato il setup di FakeNet-NG e di Wireshark per intercettare eventuali richieste che provengono dall'esterno. Una volta avviato, è possibile notare che il malware tenta di stabilire una connessione HTTPS cifrata verso il proprio server C2.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.159.142	150.171.110.53	TCP	55	49695 → 443 [ACK] Seq=1 Ack=1 Win=62941 Len=1
2	0.219016600	192.168.159.142	150.171.27.11	TCP	55	49688 → 443 [ACK] Seq=1 Ack=1 Win=64240 Len=1
3	4.313688500	192.168.159.142	192.168.159.2	DNS	76	Standard query 0xac2d A dns.msftncsi.com
4	4.319365600	192.168.159.2	192.168.159.142	DNS	92	Standard query response 0xac2d A dns.msftncsi.com A 131.107.255.255
5	9.896845600	192.168.159.142	192.168.159.2	DNS	82	Standard query 0x9804 A api.skycloudcenter.com
6	9.933067100	192.168.159.2	192.168.159.142	DNS	155	Standard query response 0x9804 No such name A api.skycloudcenter.com SOA a.gtld-servers.net
7	14.938072400	192.168.159.142	192.168.159.2	DNS	82	Standard query 0xc1e5 A api.skycloudcenter.com
8	14.980453900	192.168.159.2	192.168.159.142	DNS	155	Standard query response 0xc1e5 No such name A api.skycloudcenter.com SOA a.gtld-servers.net
9	19.985007200	192.168.159.142	192.168.159.2	DNS	82	Standard query 0x6d53 A api.skycloudcenter.com
10	19.989490200	192.168.159.2	192.168.159.142	DNS	155	Standard query response 0x6d53 No such name A api.skycloudcenter.com SOA a.gtld-servers.net
11	19.990653400	192.168.159.142	192.168.159.2	DNS	76	Standard query 0xc26c A upad.localdomain
12	20.408400600	fe80::f532:51ac:c36...	ff02::1::3	LLMNR	84	Standard query 0xb3d3 A upad
13	20.408401400	192.168.159.1	224.0.0.252	MDNS	70	Standard query 0x0000 A upad.local, "QM" question
14	20.408901300	192.168.159.1	224.0.0.251	MDNS	90	Standard query 0x0000 A upad.local, "QM" question
15	20.410240900	fe80::f532:51ac:c36...	ff02::fb	MDNS	90	Standard query 0x0000 A upad.local, "QM" question
16	20.411612700	192.168.159.1	224.0.0.251	MDNS	70	Standard query 0x0000 A upad.local, "QM" question

Figura 1.7: Wireshark Traffic Capture

Grazie a FakeNet-NG, è stato possibile intercettare alcune richieste POST HTTP, con i seguenti dettagli principali:

- **Host remoto:** `api.skycloudcenter.com`
- **Indirizzo IP reale di C2 (Threat Intelligence):** L'analisi del traffico reale e i report di intelligence collegano il dominio `api.skycloudcenter.com` del gruppo Lotus Blossom principalmente a:

- È stato rinvenuto un indirizzo IP **61.4.102.97**, geolocalizzato in Malesia, ma ritenuto benevolo.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Non è stato possibile ottenere ulteriori indirizzi, siccome le query DNS non hanno dato riscontro.

- **Struttura della richiesta POST** estratta tramite FakeNet-NG:

```
1 POST /a/chat/s/70521ddf-a2ef-4adf-9cf0-6d8e24aaa821 HTTP/1.1
2 Host: api.skycloudcenter.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.4044.92
  Safari/537.36
4 Content-Type: text/html
```

- **Payload:** Il payload HTTP cifrato, indizio dell'uso di HTTPS per l'esfiltrazione dei dati.

Monitoraggio processo per esfiltrazione dei dati

Tramite Process Monitor è possibile confermare che l'origine del traffico proviene dal processo BluetoothService.exe.

1. **Analisi del flusso TCP:** Questo conferma che BluetoothService.exe invia richieste verso l'IP di laboratorio 192.0.2.123 sulla porta 443 (HTTPS), che viene intercettata da FakeNet per l'esfiltrazione di dati. Il relativo payload rinvenuto da FakeNet risulta cifrato a causa dell'uso del protocollo di trasporto TLS/HTTPS.

8:51:09.343	BluetoothService.exe	7952	TCP Send	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 51, starttime: 1060692, endtime: 1060693...
8:51:09.345	BluetoothService.exe	7952	TCP Send	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 495, starttime: 1060692, endtime: 1060693...
8:51:09.351	BluetoothService.exe	7952	TCP Receive	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 153, seqnum: 0, connid: 0
8:51:09.352	BluetoothService.exe	7952	TCP Receive	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 1460, seqnum: 0, connid: 0
8:51:09.352	BluetoothService.exe	7952	TCP Receive	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 16, seqnum: 0, connid: 0
8:51:09.354	BluetoothService.exe	7952	TCP Disconnect	malware-vm.localdomain:50958 -> 192.0.2.123:https	SUCCESS	Length: 0, seqnum: 0, connid: 0
8:51:14.367	BluetoothService.exe	7952	TCP Connect	malware-vm.localdomain:50959 -> 192.0.2.123:https	SUCCESS	Length: 0, mss: 1460, sackopt: 1, isopt: 0, wsopt: 1...
8:51:14.368	BluetoothService.exe	7952	TCP Send	malware-vm.localdomain:50959 -> 192.0.2.123:https	SUCCESS	Length: 381, starttime: 1061195, endtime: 1061195...
8:51:14.369	BluetoothService.exe	7952	TCP Receive	malware-vm.localdomain:50959 -> 192.0.2.123:https	SUCCESS	Length: 109, seqnum: 0, connid: 0

Figura 1.8: Dettaglio del traffico TCP in Procmon

2. **Analisi dello Stack Trace e Deviazione del Traffico (tcp_send_traffic.png):**

- **Deviazione del traffico via WinDivert:** Lo stack trace dell'evento TCP Send rivela che il malware intercetta e inietta pacchetti a basso livello nel Windows Filtering Platform (fwpkclnt.sys) tramite FwpsStreamInjectAsync0/FwpsInjectNetworkSendAsync0 e Wdf01000.sys), bypassando le API socket standard (ws2_32.dll) tramite il driver WinDivert64.sys.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

- **Indicatori di Packaging (PyInstaller) ed Esecuzione:** La presenza del percorso temporaneo `_MEIxxxxxx` (es. `_MEI28002`) indica che il malware è pacchettizzato in Python tramite PyInstaller, il quale scompatta a runtime il modulo `pydivert` e il rispettivo driver. Lo user-mode stack evidenzia inoltre un'esecuzione a 32 bit in ambiente WoW64, con caricamento del driver direttamente durante l'inizializzazione del thread.

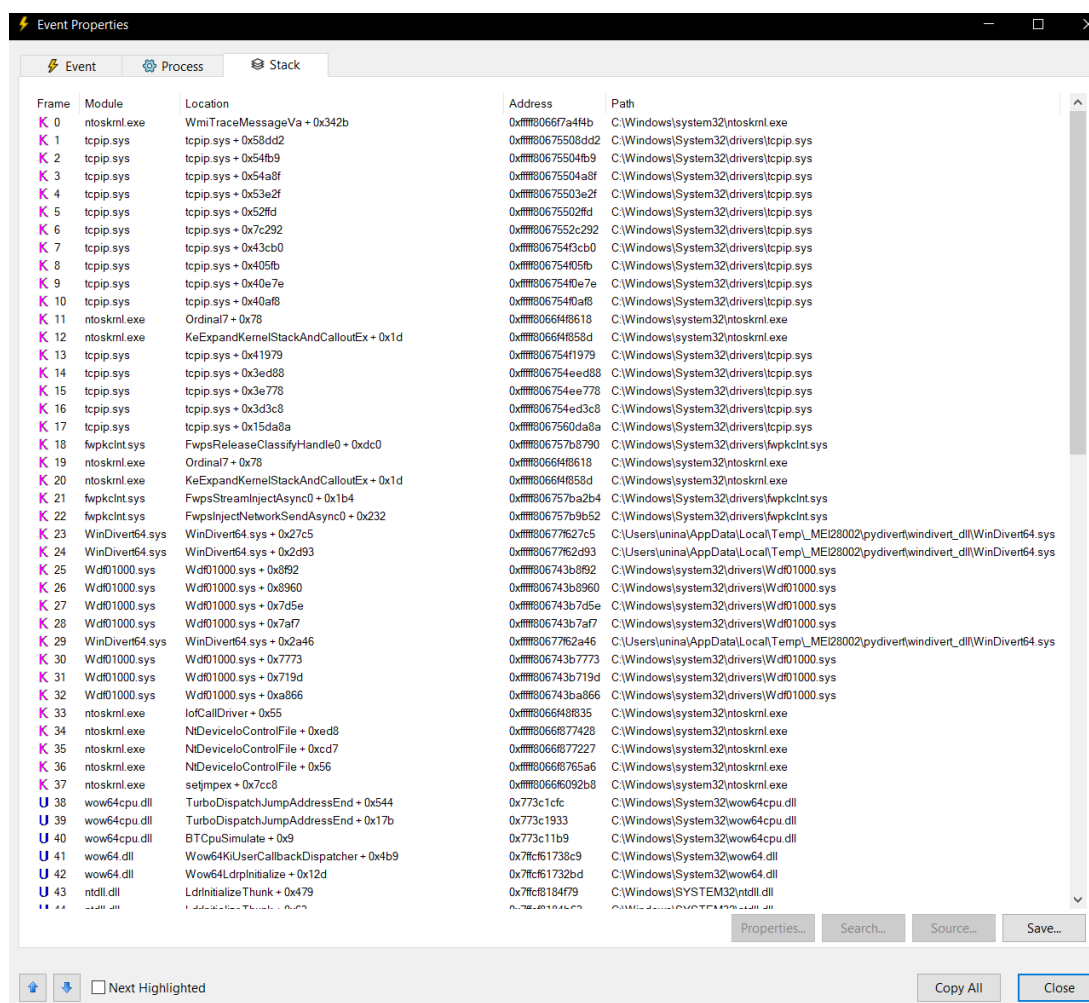


Figura 1.9: Stack Trace del TCP Send con WinDivert

Persistenza e Chiavi di Registro

Si può anche osservare che il malware registra un servizio di sistema denominato `BluetoothService` per garantirne l'esecuzione automatica ad ogni avvio dell'host. Questo servizio viene riportato all'interno del registro di sistema.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

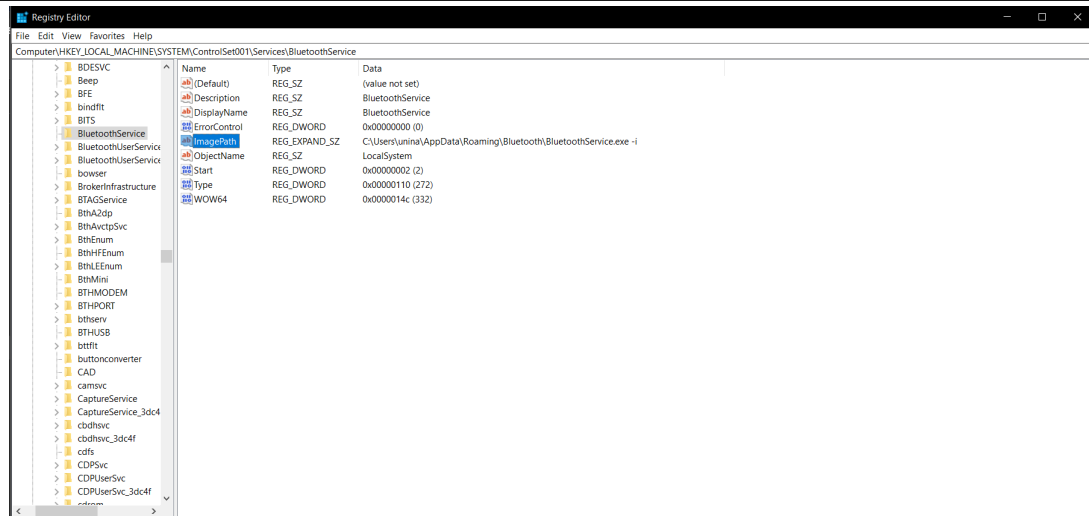


Figura 1.10: Chiave di Registro BluetoothService

- **Servizio creato:** BluetoothService
- **Chiave** **di** **registro:**
HKLM\SYSTEM\CurrentControlSet\Services\BluetoothService
- **Comando** **di** **esecuzione:**
C:\Users\unina\AppData\Roaming\Bluetooth\BluetoothService.exe -i (eseguito con privilegi di LocalSystem).



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Time	Process Name	PID	Operation	Path	Result	Detail
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 37, Name: AppMgmt
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 38, Name: AppReadiness
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 39, Name: AppVClient
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 40, Name: AppVStrm
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 41, Name: AppVemgr
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 42, Name: AppVfs
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 43, Name: AppXSvc
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 44, Name: arcsas
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 45, Name: AssignedAccessManagerSvc
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 46, Name: AsyncMac
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 47, Name: atapi
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 48, Name: AudioEndpointBuilder
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 49, Name: Audiosrv
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 50, Name: autotimesvc
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 51, Name: AxInstSV
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 52, Name: b06bdrv
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 53, Name: bam
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 54, Name: BasicDisplay
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 55, Name: BasicRender
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 56, Name: BattC
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 57, Name: BcastDVRUserService
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 58, Name: BcastDVRUserService_3dc4f
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 59, Name: bcmfm2
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 60, Name: BDESVC
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 61, Name: Beep
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 62, Name: BFE
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 63, Name: binfmt
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 64, Name: BITS
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 65, Name: BluetoothService
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 66, Name: BluetoothUserService
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 67, Name: BluetoothUserService_3dc4f
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 68, Name: browser
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 69, Name: BrokerInfrastructure
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 70, Name: BTAGService
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 71, Name: BthA2dp
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 72, Name: BthAvctpSvc
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 73, Name: BthEnum
8:37:04...	svchost.exe	6540	RegEnumKey	HKLM\System\CurrentControlSet\Services	SUCCESS	Index: 74, Name: BthHFPEnum

Figura 1.11: Procmon Service Registry Enumeration

Inoltre, grazie a ProcMon, possiamo osservare che il processo di sistema `svchost.exe` (PID 6540) esegue un'operazione di enumerazione del registro (`RegEnumKey`) sotto `HKLM\System\CurrentControlSet\Services`, caricando e individuando con successo la chiave del servizio `BluetoothService` creata dal malware (all'indice 65) per avviarne poi l'esecuzione di `BluetoothService.exe`.

Durante l'esecuzione, il malware effettua la profilazione del sistema leggendo l'identificativo univoco della macchina tramite la chiave:

- `HKLM\Software\Microsoft\Cryptography\MachineGuid`



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Time o...	Process Name	PID	Operation	Path	Result	Detail
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography	SUCCESS	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegSetValue	HKLM\Software\Microsoft\Cryptography\MachineGuid	SUCCESS	KeySelfInformationClass: KeySelfHandleTagsInfo...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography\MachineGuid	Buffer OVERFL...	Length: 12
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography\MachineGuid	SUCCESS	Type REG_SZ, Length: 74, Data: ed95936-bc2a...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography\MachineGuid	Buffer OVERFL...	Length: 49
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\Cryptography	SUCCESS	Type REG_SZ, Length: 74, Data: ed95936-bc2a...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Wow6432Node\Microsoft\Cryptography\OpenSsl	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Wow6432Node\Microsoft\Cryptography\Default\Provider\Microsoft Enhanced RSA	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKUS-1-5-18	REPARSE	Desired Access: Maximum Allowed
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Desired Access: Maximum Allowed, Granted Acc...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT\Software\Microsoft\Windows\CurrentVersion\WinTrust\Trust Providers\Software Publish...	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT\Software\Microsoft\Windows\CurrentVersion\WinTrust\Trust Providers\Software Publish...	SUCCESS	Desired Access: Read, Disposition: REG_OPEN, KeySelfInformationClass: KeySelfHandleTagsInfo...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Type REG_DWORD, Length: 4, Data: 146432
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT\Software\Microsoft\Windows\CurrentVersion\WinTrust\Trust Providers\Software Publish...	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKUS-1-5-18	REPARSE	Desired Access: Maximum Allowed
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Desired Access: Maximum Allowed, Granted Acc...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT\Software\Microsoft\Internet Explorer\Security	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Wow6432Node\Policies\Microsoft\SystemCertificates\TrustedPublisher\Safer	REPARSE	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKUS-1-5-18	REPARSE	Desired Access: Maximum Allowed
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Desired Access: Maximum Allowed, Granted Acc...
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT\Software\Policies\Microsoft\SystemCertificates\TrustedPublisher\Safer	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKU\DEFAULT	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Handle Tags. Handle Tags: 0x0
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM	SUCCESS	Query Name
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Wow6432Node\Microsoft\SystemCertificates\TrustedPublisher\Safer	REPARSE	Desired Access: Read
14:17...	BluetoothService.exe	7952	RegOpenKey	HKLM\Software\Microsoft\SystemCertificates\TrustedPublisher\Safer	NAME NOT FOUND	Desired Access: Read
14:17...	BluetoothService.exe	7952	TCP Send	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 21, starttime: 1001530, endtime: 1001530. s...
14:17...	BluetoothService.exe	7952	TCP Receive	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 495, starttime: 1001530, endtime: 1001530...
14:17...	BluetoothService.exe	7952	TCP Receive	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 153, sequum: 0, connid: 0
14:17...	BluetoothService.exe	7952	TCP Receive	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 1460, sequum: 0, connid: 0
14:17...	BluetoothService.exe	7952	TCP Receive	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 16, sequum: 0, connid: 0
14:17...	BluetoothService.exe	7952	TCP Disconnect	malware-vn.localdomain:5935 -> 192.0.2.123:https	SUCCESS	Length: 0, sequum: 0, connid: 0

Figura 1.12: Procmon MachineGuid e Traffico di Rete

Evasione, Monitoraggio e Chiusura

Durante il monitoraggio dell'esecuzione del malware tramite Process Monitor, si osserva la terminazione improvvisa del thread principale e del processo una volta completata l'iniezione, allo scopo di eludere l'analisi dinamica.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Process Monitor - Sysinternals: www.sysinternals.com						
File Edit Event Filter Tools Options Help						
Time o...	Process Name	PID	Operation	Path	Result	Detail
8:37:36...	vm3dservice.exe	2412	RegCloseKey	HKLM\System\CurrentControlSet\Control\Clas...	SUCCESS	
8:37:36...	vm3dservice.exe	2412	RegOpenKey	HKLM\System\CurrentControlSet\Enum\PCI\...	SUCCESS	Desired Access: Query Value, Maximum Allowed
8:37:36...	vm3dservice.exe	2412	RegQueryValue	HKLM\System\CurrentControlSet\Enum\PCI\...	BUFFER OVERFL...	Length: 268
8:37:36...	vm3dservice.exe	2412	RegCloseKey	HKLM\System\CurrentControlSet\Enum\PCI\...	SUCCESS	
8:37:36...	vm3dservice.exe	2412	RegOpenKey	HKLM\System\CurrentControlSet\Enum\PCI\...	SUCCESS	Desired Access: Query Value, Maximum Allowed
8:37:36...	vm3dservice.exe	2412	RegQueryValue	HKLM\System\CurrentControlSet\Enum\PCI\...	SUCCESS	Type: REG_MULTI_SZ, Length: 292, Data: PCI\...
8:37:36...	vm3dservice.exe	2412	RegCloseKey	HKLM\System\CurrentControlSet\Enum\PCI\...	SUCCESS	
8:37:36...	vm3dservice.exe	2412	RegOpenKey	HKLM\Hardware\DeviceMap\Video	SUCCESS	Desired Access: Read
8:37:36...	vm3dservice.exe	2412	RegQueryValue	HKLM\Hardware\DeviceMap\Video\ID...	SUCCESS	Type: REG_SZ, Length: 202, Data: \Registry\Mac...
8:37:36...	vm3dservice.exe	2412	RegCloseKey	HKLM\Hardware\DeviceMap\Video	SUCCESS	
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 1
8:37:37...	dwm.exe	1020	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\DW...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 4280953386
8:37:37...	BluetoothServ...	7952	Thread Exit		SUCCESS	Thread ID: 6352, User Time: 0.0000000, Kernel Ti...
8:37:37...	vm3dservice.exe	2412	RegOpenKey	HKLM\Hardware\DeviceMap\Video	SUCCESS	Desired Access: Read, Maximum Allowed
8:37:37...	vm3dservice.exe	2412	RegQueryValue	HKLM\Hardware\DeviceMap\Video\ID...	SUCCESS	Type: REG_DWORD, Length: 4, Data: 8
8:37:37...	vm3dservice.exe	2412	RegCloseKey	HKLM\Hardware\DeviceMap\Video	SUCCESS	
8:37:37...	vm3dservice.exe	2412	RegOpenKey	HKLM\Hardware\DeviceMap\Video	SUCCESS	Desired Access: Read
8:37:37...	vm3dservice.exe	2412	RegQueryValue	HKLM\Hardware\DeviceMap\Video\ID...	SUCCESS	Type: REG_SZ, Length: 202, Data: \Registry\Mac...
8:37:37...	vm3dservice.exe	2412	RegOpenKey	HKLM\System\CurrentControlSet\CONTROL\...	REPARSE	Desired Access: Read

Showing 102,532 of 268,530 events (38%) Backed by virtual memory

Figura 1.13: Procmon Thread Exit



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Frame	Module	Location	Address	Path
K 0	ntoskrnl.exe	NtFindAtom + 0x889	0xffff8066f803ce9	C:\Windows\system32\ntoskrnl.exe
K 1	ntoskrnl.exe	KeUserModeCallback + 0x12c9	0xffff8066f8b24d9	C:\Windows\system32\ntoskrnl.exe
K 2	ntoskrnl.exe	LpcRequestPort + 0x23f3	0xffff8066f8b5853	C:\Windows\system32\ntoskrnl.exe
K 3	ntoskrnl.exe	LpcRequestPort + 0x237a	0xffff8066f8b57da	C:\Windows\system32\ntoskrnl.exe
K 4	ntoskrnl.exe	setjmpex + 0x7cc8	0xffff8066f6092b8	C:\Windows\system32\ntoskrnl.exe
U 5	wow64cpu.dll	TurboDispatchJumpAddressEnd + 0x544	0x773c1cfc	C:\Windows\System32\wow64cpu.dll
U 6	wow64cpu.dll	TurboDispatchJumpAddressEnd + 0x503	0x773c1cbb	C:\Windows\System32\wow64cpu.dll
U 7	wow64cpu.dll	BTCPuSimulate + 0x9	0x773c11b9	C:\Windows\System32\wow64cpu.dll
U 8	wow64.dll	Wow64KiUserCallbackDispatcher + 0x4b9	0x77c61738c9	C:\Windows\System32\wow64.dll
U 9	wow64.dll	Wow64LdrpInitialize + 0x12d	0x77c61732bd	C:\Windows\System32\wow64.dll
U 10	ntdll.dll	LdrInitializeThunk + 0x479	0x77c6184f79	C:\Windows\SYSTEM32\ntdll.dll
U 11	ntdll.dll	LdrInitializeThunk + 0x63	0x77c6184b63	C:\Windows\SYSTEM32\ntdll.dll
U 12	ntdll.dll	LdrInitializeThunk + 0xe	0x77c6184b0e	C:\Windows\SYSTEM32\ntdll.dll
U 13	ntdll.dll	NtTerminateThread + 0xc	0x77442eec	C:\Windows\SysWOW64\ntdll.dll
U 14	ntdll.dll	RtlExitUserThread + 0x59	0x7743b4e9	C:\Windows\SysWOW64\ntdll.dll
U 15	ntdll.dll	TpCallbackIndependent + 0x87c	0x7740601c	C:\Windows\SysWOW64\ntdll.dll
U 16	KERNEL32.DLL	BaseThreadInitThunk + 0x19	0x7719fa29	C:\Windows\SysWOW64\KERNEL32.DLL
U 17	ntdll.dll	RtlGetAppContainerNamedObjectPath + 0x11e	0x77437a7e	C:\Windows\SysWOW64\ntdll.dll
U 18	ntdll.dll	RtlGetAppContainerNamedObjectPath + 0xee	0x77437a4e	C:\Windows\SysWOW64\ntdll.dll

Figura 1.14: Stack Trace Thread Exit

La stack trace dell'evento di Thread Exit mostra come l'esecuzione passi attraverso le librerie `wow64cpu.dll` (`BTCPuSimulate`) e `ntdll.dll` (`NtTerminateThread`), a conferma del fatto che il malware avvia il proprio codice e poi termina il thread primario per disorientare i debugger.

1.4 Roadmap di Analisi Operativa

Possiamo confermare, quindi, che il malware è formato dalle seguenti componenti:

1. L'Installer **NSIS** (**update.exe**):

sha256:8ea8b83645fba6e23d48075a0d3fc73ad2ba515b4536710cda4f

Avvia l'infezione estraendo tre componenti principali all'interno della cartella `%appdata%\Roaming\Bluetooth\`:

- **BluetoothService.exe**

sha256:2da00de67720f5f13b17e9d985fe70f10f153da60c9ab108

(un eseguibile legittimo firmato da Bitdefender, originariamente `BDSUBWIZMT.exe`).



- **log.dll**

sha256:3bdc4c0637591533f1d4198a72a33426c01f69bd2e15ceee
(la libreria dinamica malevola).

- **BluetoothService**

sha256:77bfea78def679aa1117f569a35e8fd1542df21f7e00e27f
(il payload contenente lo shellcode offuscato, privo di estensione).

2. **DLL Sideloadig:** All'avvio di `BluetoothService.exe`, il sistema operativo Windows carica automaticamente `log.dll` presente nella stessa cartella (sideloading).
 3. **Esecuzione dello Shellcode:** La funzione di inizializzazione di `log.dll` (`DllMain` / `LogInit`) legge il file `BluetoothService` crittografato dal disco, lo decrittografa in memoria RAM usando un algoritmo matematico custom e vi trasferisce l'esecuzione.
- **Comunicazione C2:** Il payload finale decrittato (backdoor Chrysalis) effettua la profilazione dell'host e si connette al server di Command and Control (C2) per l'esfiltrazione e la ricezione di comandi.

L'architettura del flusso di esecuzione è riassunta nel seguente diagramma:

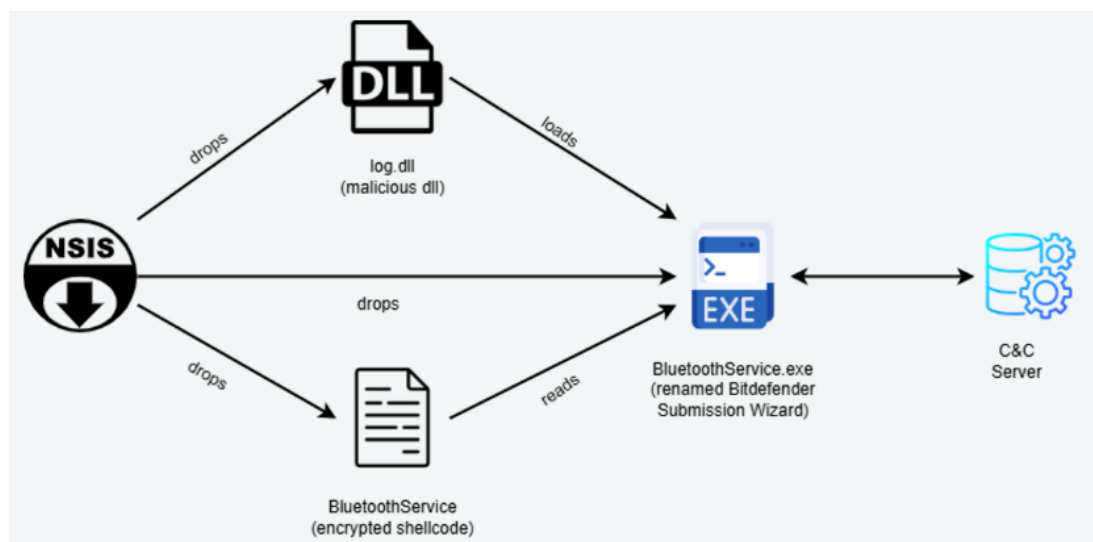


Figura 1.15: Architettura di esecuzione Chrysalis



1.4.1 Analisi di Dettaglio dei Componenti e Ingegneria Inversa

update.exe (Dropper NSIS)

- **Tecnologia:** Archivio autoinstallante NSIS (Nullsoft Scriptable Install System).
- **Funzione principale:** Estrae i componenti malevoli nella directory di sistema %APPDATA%\Roaming\Bluetooth\.
- **Tecniche di Evasione e Permessi NTFS Custom:**
 - **DACL personalizzata:** La subroutine sub_405B06 definisce un descrittore di sicurezza personalizzato applicato alla cartella creata. Nello specifico, imposta una DACL con due ACE (Access Control Entries):
 1. *ACE 1:* Permessi di ACCESS_ALLOWED su BUILTIN\Administrators con flag GENERIC_ALL (controllo completo).
 2. *ACE 2:* Permessi di ACCESS_ALLOWED su Everyone limitati esclusivamente a READ_CONTROL, FILE_READ_DATA, FILE_DELETE_CHILD e SYNCHRONIZE. Questa configurazione impedisce modifiche o scritture successive ma consente la lettura e la cancellazione manuale del contenuto.
 - **Attributi Hidden/System:** L'installer richiama l'API SetFileAttributesW per camuffare i file estratti sul file system. La funzione sub_401434 ricicla il parametro nCmdShow della funzione WinMain dell'eseguibile (tipicamente impostato a 2 o 6) passandolo direttamente come dwFileAttributes. Se il valore corrisponde a tali costanti, i file e la cartella vengono configurati come nascosti o di sistema (FILE_ATTRIBUTE_HIDDEN o HIDDEN|SYSTEM), celandoli a ricerche visive superficiali da parte dell'utente.
 - **Persistenza nel Registro:** L'archivio NSIS contiene uno script compilato (opcode 0x33) che richiama RegSetValueExW per registrare il valore BluetoothService sotto la chiave di avvio automatico HKCU\Software\Microsoft\Windows\CurrentVersion\Run, puntando all'eseguibile esca.



BluetoothService.exe (Loader & Esca Sideloaded)

- **Firma e Autenticità:** Originariamente l'eseguibile `BDSUBWIZMT.exe` (Bitdefender Submission Wizard), firmato digitalmente ma vulnerabile. Il malware lo utilizza come esca legittima per forzare il caricamento dinamico della libreria malevola presente nella stessa directory.
- **Flusso di Caricamento (`LogLoader_Init`):**
 - La subroutine `sub_404760` recupera la directory in cui risiede l'eseguibile tramite `GetModuleFileNameW`.
 - Sostituisce il nome dell'eseguibile nel percorso per concatenare ed individuare il file `log.dll`.
 - Effettua il caricamento manuale della libreria tramite `LoadLibraryW(L"log.dll")`.
 - Risolve dinamicamente le esportazioni di `log` richiamando `GetProcAddress` per le funzioni `LogInit`, `LogWrite`, `LogApplySettings`, e altre.
 - Salva i puntatori a queste funzioni all'interno di una struttura globale (`dword_4BCFBC`).
 - Avvia l'esecuzione del malware richiamando immediatamente l'esportazione `LogInit()` risolta dal DLL.

log.dll (Loader Intermedio e API Hashing)

- **Falsi Metadati:** La DLL esporta funzioni con nomi fittizi tipici di librerie di logging per mascherare la sua natura malevola. Le funzioni risolte a runtime sono:
 - `LogInit`: Inizializza l'ambiente e alloca l'area di memoria heap.
 - `LogWrite`: Scrive ed esegue lo shellcode in memoria dopo averlo decifrato.
 - `LogApplySettings`, `LogSetSettingsFile`, `LogEnable`, `LogSetLevel`, `LogSetPath`, `LogSetType`, `LogSetMode`, `LogSetMaxSize`, `LogSetDepth`, `LogMonitorSettings`, `LogGetLevel`: Routine fittizie di configurazione e logging.
 - `LogIsEnabled`, `LogTrackEvent`, `LogTrackEventData`, `LogRemoveModule`, `LogUninitDeskMetrics`: Funzioni ausiliarie e di tracciamento fittizio.



- **Meccanismo di API Hashing:**

- Per evitare il rilevamento delle API importate, la libreria risolve gli indirizzi delle funzioni a runtime scorrendo le Export Table dei DLL caricati (come `winhttp.dll`, `dnsapi.dll`, `ws2_32.dll`) tramite la subroutine `sub_100014E0`.
- **Algoritmo di hashing (FNV-1a modificato):**
 1. Calcola l'hash FNV-1a standard a 32 bit del nome dell'API (costante di inizializzazione `0x811C9DC5` e moltiplicatore `16777619`).
 2. Esegue un'operazione XOR dell'hash con il suo shift logico a destra di 15 bit: $h = h \oplus (h \gg 15)$.
 3. Moltiplica il valore ottenuto per la costante `-2048144789` (ovvero `0x85EB87EB`).
 4. Esegue un'operazione XOR dell'hash finale con il suo shift a destra di 13 bit: $h = h \oplus (h \gg 13)$.
 5. Somma all'hash calcolato una chiave statica inizializzata all'avvio a `535972289` (`0x1FF09DC1`): $\text{hash_finale} = h + 0x1FF09DC1$.
- Di seguito sono riportati gli hash decodificati delle API risolte da `log.dll`:

- * **winhttp.dll:** `WinHttpOpen` (`0x68C6D1D7`),
`WinHttpConnect` (`0xB26E0E90`), `WinHttpRequest`
(`0xB22C9C14`), `WinHttpSendRequest` (`0x069E8B9B`),
`WinHttpReceiveResponse` (`0x06AEB5BB`),
`WinHttpReadData` (`0x28F634E3`),
`WinHttpSetStatusCallback` (`0x4E6B404E`),
`WinHttpSetTimeouts` (`0x8E867846`).
- * **kernel32.dll:** `VirtualAlloc` (`0xBA4AE021`),
`VirtualProtect` (`0x7DADB766`), `CreateThread`
(`0xEA8D815C`), `WaitForSingleObject` (`0x31854D48`),
`LoadLibraryA` (`0xE0CDA96B`), `GetProcAddress`
(`0xB3A0A405`).
- * **wininet.dll:** `InternetOpenW` (`0x2482E712`),
`InternetConnectW` (`0x37C94070`), `HttpOpenRequestW`
(`0xD42E1C6B`), `HttpSendRequestW` (`0xAFFE7343`),
`InternetReadFile` (`0x19CD23D9`).
- * **dnsapi.dll:** `DnsQuery_W` (`0x3E77D6C4`), `DnsQuery_A`
(`0x00C99B0D`), `DnsFree` (`0x297ABAA0`).



* **ws2_32.dll**: WSASStartup (0x098E4D98), WSASocketW (0x1553FF5F), connect (0x9348B408), send (0x20C5BD00), recv (0x10A4DD14), closesocket (0xEA5FEB68).

- **Decrittazione e Setup dello Shellcode:**

- LogInit alloca un'area di memoria Heap da 2 MB nel processo host per accogliere lo shellcode.
- La funzione LogWrite popola il buffer allocato e vi inserisce una struttura di configurazione (v3) contenente puntatori a helper di risoluzione API ed informazioni sulla memoria.
- LogWrite richiama infine la routine crittografica sub_10001640 (decrittazione XOR progressiva a tre fasi) e trasferisce il controllo allo shellcode eseguendo una chiamata dinamica (call eax).

1.4.2 Estrazione e Analisi Dinamica dello Shellcode

La roadmap operativa si articola in due fasi sequenziali per l'estrazione, la decodifica e lo studio del payload finale:

Fase	Descrizione	Obiettivo Principale	Strumenti Utilizzati
Fase 1	Analisi Dinamica e Memory Dumping	Bypass delle tecniche di evasione ed esecuzione controllata in x32dbg per dumpare il payload decrittato in RAM.	x32dbg, ScyllaHide, Procmon, FakeNet-NG
Fase 2	Riparazione PE e Reverse Engineering	Ricostruzione della IAT e delle intestazioni PE del dump, estrazione IOC e analisi statica dettagliata del codice.	PE-bear, Ghidra, IDA Freeware, Python

Tabella 1.2: Fasi della roadmap operativa per l'estrazione e analisi dello shellcode.

In questa fase useremo **x32dbg** e **ScyllaHide** per estrarre lo shellcode dal processo `BluetoothService.exe`.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

BluetoothService.exe - PID: 1816 - Module: bluetoothservice.exe - Thread: Main Thread 1152 - x32dbg [Elevated]

File View Debug Tracing Plugins Favourites Options Help Jan 15 2023 (TitanEngine)

CPU Log Notes Breakpoints Memory Map Call Stack SEH Script Symbols Source References Threads

EntryPoint

Hide FPU

Registers: EAX 0017EE36, EBX 00860000, ECX 008F7180, EDI 00400000, EBP 0086FEFC, ESP 0086FEF0, ESI 008F7180, EIP 008F7180

Assembly:

```
008F7180 E8 08080000 call bluetoothservice.BF798D
008F7185 E9 78FEFFFF jmp bluetoothservice.BF7032
008F718A 6A 10 push 10
008F718C 68 403FC600 push bluetoothservice.C63F40
008F71C1 E8 AA060000 call bluetoothservice.BF7870
008F71C6 3308 xor ebx,ebx
008F71C8 895D E0 mov dword ptr ss:[ebp-20],ebx
008F71CB 885D E7 mov byte ptr ss:[ebp-19],bl
008F71CE 895D FC mov dword ptr ss:[ebp-4],ebx
008F71D1 8B5D 10 cmp ebx,dword ptr ss:[ebp+10]
008F71D4 74 18 je bluetoothservice.BF71F1
008F71D6 8B4D 14 mov ecx,dword ptr ss:[ebp+14]
008F71D9 FF15 6843C400 call dword ptr ds:[c44368]
008F71DE 8B4D 08 mov ecx,dword ptr ss:[ebp+8]
008F71E2 FF55 14 call dword ptr ss:[ebp+14]
008F71E5 8B4D 0C mov eax,dword ptr ss:[ebp+4]
008F71E8 0145 08 add dword ptr ss:[ebp+8],eax
008F71EB 43 inc ebx
008F71EC 895D E0 mov dword ptr ss:[ebp-20],ebx
008F71EF jmp bluetoothservice.BF71D1
008F71F1 B0 01 mov al,1
008F71F3 8B45 E7 mov byte ptr ss:[ebp-19],al
008F71F6 C745 FC FFFFFFFF mov dword ptr ss:[ebp-4],FFFFFFFF
008F71F8 E8 18000000 call bluetoothservice.BF721A
008F7202 8B4D F0 mov ecx,dword ptr ss:[ebp-10]
008F7205 64:890D 00000000 mov dword ptr [0],ecx
008F720C 59 pop ecx
008F720D 5F pop edi
008F720E 5E pop esi
008F720F 5B pop ebx
008F7210 C9 leave
008F7211 C2 1400 ret 14
008F7214 8B5D E0 mov ebx,dword ptr ss:[ebp-20]
008F7217 8B5D E7 mov al,byte ptr ss:[ebp-19]
008F721A 84C0 test al,al
008F721C 75 0F jne bluetoothservice.BF722D
008F721E FF75 18 push dword ptr ss:[ebp+18]
008F7221 53 push ebx
008F7222 FF75 0C push dword ptr ss:[ebp+4]
008F7225 FF75 08 push dword ptr ss:[ebp+8]
```

bluetoothservice.008F798D

.text:008F7180 bluetoothservice.exe:\$47180 #46580 <EntryPoint>

Dump 1 Dump 2 Dump 3 Dump 4 Dump 5 Watch 1 Locals

Address Hex ASCII

77021000 16 00 18 00 28 7c 02 77 14 00 16 00 78 74 02 77 ...(.|...xt.w

77021010 00 00 02 00 EC 5D 02 77 0E 00 10 00 00 7E 02 77 ...U...w...

77021020 0C 00 0E 00 F0 7D 02 77 08 00 0A 00 D8 73 02 77 ...D.w...s.w

77021030 06 00 08 00 0D 7D 02 77 06 00 08 00 E0 7D 02 77 ...D.w...a.w

77021040 06 00 08 00 28 7D 02 77 06 00 08 00 E8 7D 02 77 ...D.w...e.w

77021050 1C 00 1E 00 D4 74 02 77 68 4C 73 45 00 00 01 77 ...Ot.wkLse...

77021060 00 39 14 77 00 00 00 00 60 17 02 77 70 08 08 77 9.w....wp0.w

77021070 20 00 22 00 80 02 77 84 00 86 00 F0 7F 02 77 ...x.w...d.w

77021080 70 8B 05 77 60 47 12 77 20 84 04 77 A0 45 12 77 pk.w.G.w..wE.w

77021090 70 1E 05 77 00 69 05 77 20 46 12 77 E0 46 12 77 p.w.i.w.f.waf.w

770210A0 E0 56 05 77 60 47 12 77 00 25 05 77 00 69 05 77 av.w.G.w.%w.i.w

770210B0 70 46 12 77 20 46 12 77 A0 45 12 77 60 47 12 77 pf.waf.w.i.w.G.w

770210C0 00 00 00 00 57 14 01 E2 46 15 C5 43 A5 FE 00 8D ..w..af.AC4p...

770210D0 EE E3 D3 F0 06 00 00 00 5C 74 02 77 01 00 00 00 iad0...t.w...

770210E0 9A 88 13 35 50 80 4F 5E 7D 72 44 02 25 F9 3A ...S.p0..d034

770210F0 06 00 01 00 40 74 02 77 02 00 00 00 E3 28 2F 4A ...Et.w...a(3/

Command: Commands are comma separated (like assembly instructions): mov eax, ebx

Paused INT3 breakpoint "entry breakpoint" at <bluetoothservice.EntryPoint> (008F7180)

Time Wasted Debugging: 0:00:16:53

Figura 1.16: Entry Point di BluetoothService.exe

Sintesi dei Tentativi e degli Ostacoli Incontrati

L'estrazione del payload ha richiesto il superamento di molteplici tecniche di evasione implementate dall'APT Lotus Blossom. Di seguito i passaggi fondamentali del diario di analisi:

1. **Evasione Iniziale (Bait and Switch):** I primi tentativi di usare Software Breakpoints sulle API standard e ScyllaHide si sono rivelati inefficaci. Il malware, una volta rilevato il debugger, clona se stesso in background ed evade l'analisi terminando il processo principale.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

The screenshot shows the x32dbg debugger interface. The title bar indicates the process is BluetoothService.exe (PID: 1816) and the module is kernel32.dll. The CPU window shows assembly instructions, with a breakpoint set on the instruction at address 763804C6: `jmp dword ptr ds:[<VirtualProtect>]`. The Memory window shows the memory dump at the breakpoint address, displaying ASCII and hexadecimal data. The Watch window shows the value of the `EIP` register, which is 763804C0. The Command window shows the command: `Commands are comma separated (like assembly instructions): mov eax, ebx`.

Figura 1.17: Breakpoint su VirtualProtect

- Esecuzione Precoce in DllMain:** Un'analisi architetturale ha rivelato che il codice malevolo non attende il raggiungimento dell'Entry Point ufficiale dell'eseguibile, ma si innesca direttamente nella DllMain appena `log.dll` viene caricata in memoria. È stato quindi necessario riconfigurare x32dbg per intercettare l'esecuzione "User DLL Entry".



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

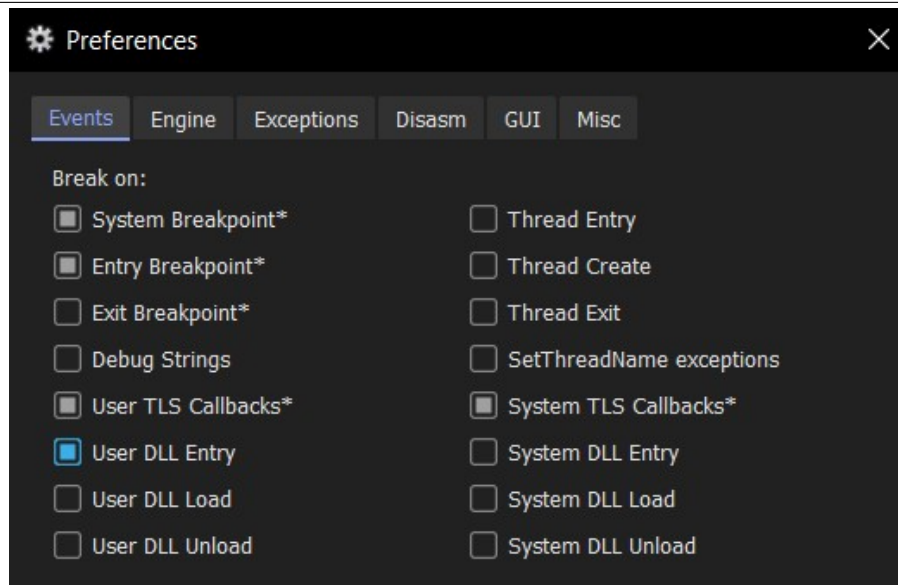


Figura 1.18: Preferenze x32dbg

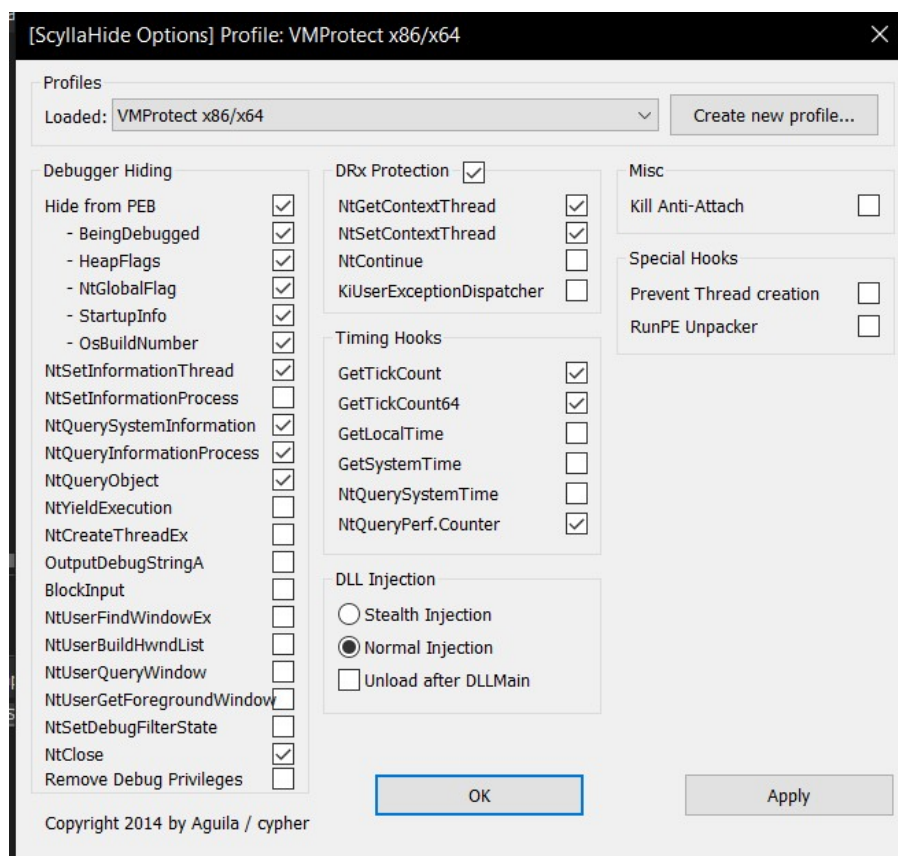


Figura 1.19: Opzioni ScyllaHide

3. **Trappole nella Memoria e False Piste (Decoy PE):** Tramite Hardware Breakpoints su API native (come



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

ZwProtectVirtualMemory), si è isolato un eseguibile in memoria. La sua ricostruzione (tramite PE-bear per correggere i Section Headers) ha però svelato un Decoy PE (esca), di dimensioni esigue e privo di codice Assembly utile.

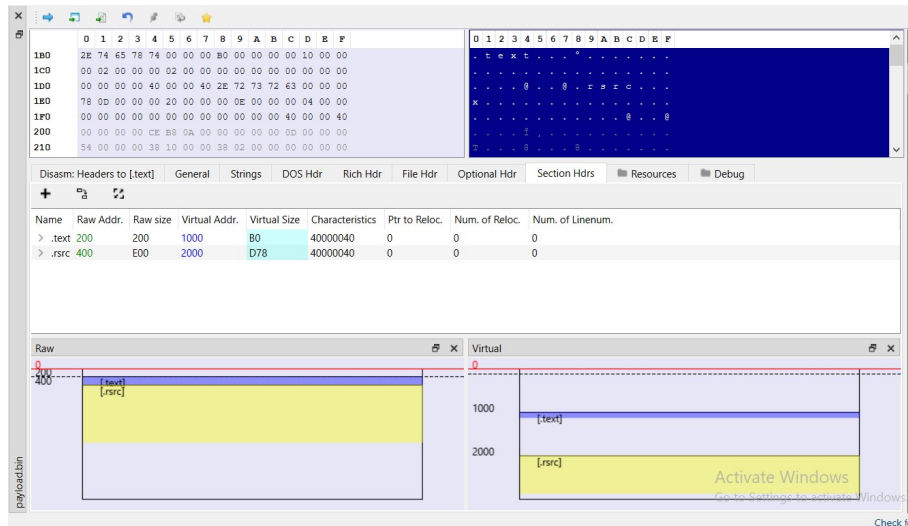


Figura 1.20: Section Headers in PE-bear

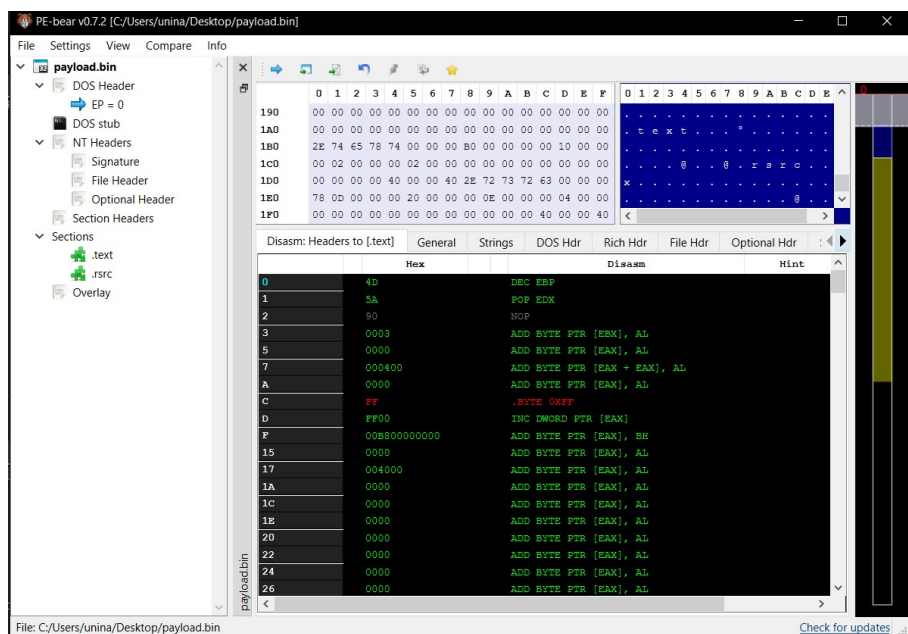


Figura 1.21: PE non valido dumpato



- | D... | Location | Label | Code Unit | String View | String Type | Length | Is Word |
|------|----------|-------|---------------------|------------------|-------------|--------|---------|
| | 0002d74c | | ds "GetProcAddress" | "GetProcAddress" | string | 15 | true |

5. **Tracking Dinamico ed Estrazione:** Conoscendo la logica, si sono impostati breakpoint mirati in x32dbg sulle routine di decrittazione, permettendo il dump finale dello shellcode, il quale decrittò il file usando una logica XOR custom e la chiave `qQ2JR&9i`.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Pattern: 4D5A900003000000	
Address	Disassembly
00400000	dec ebp
006C0000	dec ebp
70750000	dec ebp
742D0000	dec ebp
74300000	dec ebp
74390000	dec ebp
74680000	dec ebp
74D20000	dec ebp
750D0000	dec ebp
750E0000	dec ebp
75B60000	dec ebp
75FA0000	dec ebp
76280000	dec ebp
764A0000	dec ebp
76560000	dec ebp
765E0000	dec ebp
766B0000	dec ebp
76810000	dec ebp
76A70000	dec ebp
76B80000	dec ebp
76BB0000	dec ebp
76D50000	dec ebp
76DD0000	dec ebp
76EC0000	dec ebp
76EF0000	dec ebp
77010000	dec ebp
77110000	dec ebp
776D0000	dec ebp
777B0000	dec ebp
77850000	dec ebp
779E0000	dec ebp
779F0000	dec ebp

Figura 1.24: Memory Map dello shellcode in RAM



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Type	Address	Module/Label/Exception	State	Disassembly	Hits	Summary
Software	00403580	<bluetoothservice.exe.OptionalHeader.AddressOfEntryPoint>	One-time	sub esp,3F8	0	entry breakpoint
Hardware	76E03B30	<kernel32.dll.CreateProcessInternalW>	Enabled	mov edi,edi	0	execute()
	77A82B10	<ntdll.dll.NtAllocateVirtualMemory>	Enabled	mov eax,18	0	execute()
	77A82D50	<ntdll.dll.NtWriteVirtualMemory>	Enabled	mov eax,38	0	execute()
	77A62E00	<ntdll.dll.NtResumeThread>	Enabled	mov eax,70052	0	execute()

Figura 1.25: Breakpoint sulle routine di decrittazione

```
1 int LogWrite()
2 {
3     void (__stdcall *v0)(int (__cdecl *)(_DWORD), int, int, int *); // eax
4     int v2; // [esp+Ch] [ebp-6Ch] BYREF
5     int v3[25]; // [esp+10h] [ebp-68h] BYREF
6
7     v2 = 64;
8     v0 = (void (__stdcall *) (int (__cdecl *) (_DWORD), int, int, int *))sub_100014E0(dword_1001635C, 1203897546);
9     v0(dword_10016360, 0x200000, 64, &v2);
10    sub_10001640();
11    v3[0] = 0x116A7;
12    v3[1] = 5;
13    v3[19] = 181712;
14    v3[18] = 0x31000;
15    v3[16] = 0x400000;
16    v3[17] = 0;
17    v3[2] = 0x1000;
18    v3[9] = 143360;
19    v3[3] = 147456;
20    v3[10] = 36352;
21    v3[4] = 184320;
22    v3[11] = 3072;
23    v3[5] = 196608;
24    v3[12] = 512;
25    v3[6] = 200704;
26    v3[13] = 7168;
27    v3[7] = 0;
28    v3[14] = 0;
29    v3[8] = 0;
30    v3[15] = 0;
31    v3[20] = (int)dword_10016360;
32    v3[22] = (int)sub_100014D0;
33    v3[21] = (int)sub_100014C0;
34    return dword_10016360(v3);
35 }
```

Figura 1.26: Codice decompilato di LogWrite

1.4.3 Architettura del Modulo Principale (Chrysalis Backdoor)

Dopo aver estratto con successo lo shellcode, è stato possibile analizzarlo. La prima operazione che viene eseguita è il caricamento delle librerie mediante un'operazione di hashing più complessa rispetto a quella vista all'interno di LogWrite.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

The screenshot displays the IDA Pro interface. The left pane shows assembly code with addresses from 054D158F to 054D165A. The right pane shows the registers and stack. The registers pane includes EAX (032FFB48), EBX (054CAB10), ECX (00000000), EDI (00000000), ESP (032FFC58), ESI (00000005), and EDI (00000000). The stack pane shows the current stack frame and its contents, including the return address 032FFB48 and the return value 032FFC58.

Figura 1.27: Esecuzione dello Shellcode in IDA

Decrittazione della Configurazione e Destinazione C2

Successivamente, viene decrittata una zona di memoria che ospita al suo interno i parametri per una richiesta HTTP all'esterno. L'algoritmo crittografico utilizzato per questo blocco è **RC4**, impiegando la chiave hardcodata `qwhvb^435h&*7`, la quale viene caricata all'interno carattere per carattere per evadere i controlli sulle stringhe.

054C6660	8A8C35 58F5FFFF	mov cl,byte ptr ss:[ebp+esi-AA8]	
054C6667	8BD6	mov edx,esi	
054C6669	E8 82EAF5FF	call 54C50F0	
054C666E	888435 58F5FFFF	mov byte ptr ss:[ebp+esi-AA8],al	
054C6675	46	inc esi	
054C6676	83FE 0D	cmp esi,D	D: '\r'
054C6679	72 E5	jb 54C6660	
054C667B	8D85 58F5FFFF	lea eax,dword ptr ss:[ebp-AA8]	

Figura 1.28: Routine di estrazione chiave config



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

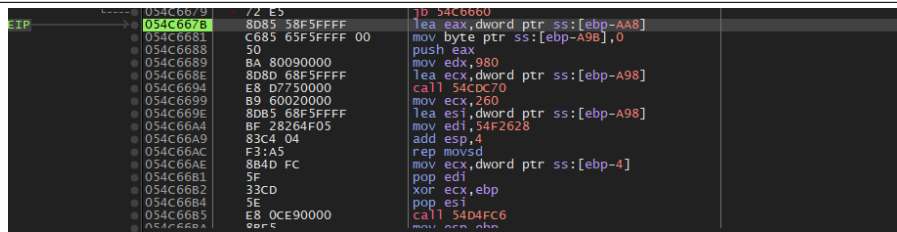


Figura 1.29: Routine RC4 Decrypt

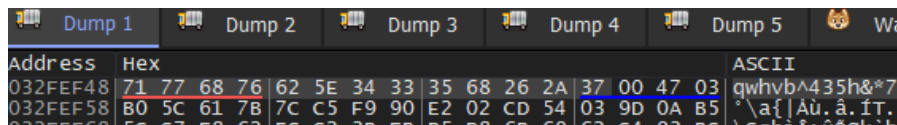


Figura 1.30: Chiave RC4 in memoria

Una volta decifrata la configurazione, il malware svela il dominio del Command and Control (C2):

- **URL di Esfiltrazione:** <https://api.skycloudcenter.com/a/chat/s/70521ddf-a2ef-4adf-9cf0-6d8e24aaa821>
- Possiamo notare anche l'indirizzo IP **61.4.102.97**.

In questo modo siamo riusciti a risalire all'URL di esfiltrazione individuato nelle fasi iniziali.

Tripla Modalità di Esecuzione

Chrysalis implementa una logica differenziata a tre vie basata sugli argomenti a riga di comando passati all'eseguibile, con lo scopo di eludere sandbox o controlli statici e instaurare la persistenza in modo silente.

1. **Modalità Installazione (Nessun parametro):** Crea un servizio di sistema o una voce di registro in modo da assicurare la persistenza all'avvio dell'host. Questo servizio esegue il malware passandogli specificamente il parametro `-i`. Completata l'installazione, il processo originario termina immediatamente.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

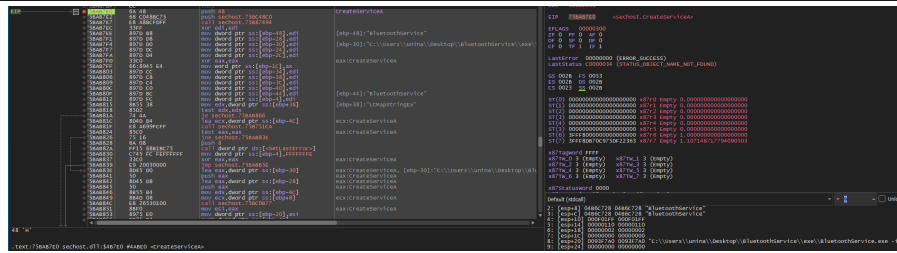


Figura 1.31: Creazione del servizio persistente

- Modalità Launcher (Parametro -i):** Genera e lancia in background una nuova istanza di se stesso tramite la funzione di sistema `ShellExecuteA`, iniettandovi il parametro `-k`. In questo modo elude il tree genitore.

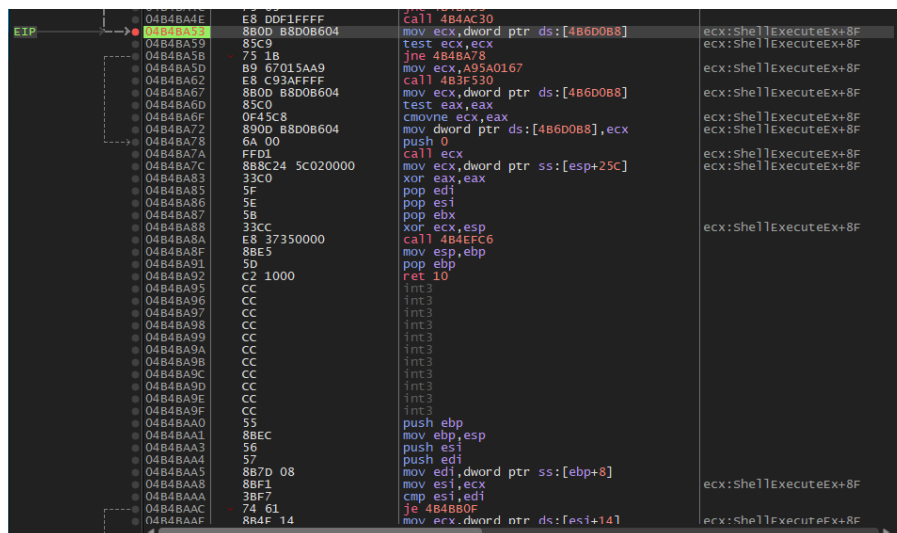


Figura 1.32: Funzione di caricamento ShellExecute

0093F2EC	76334AB5	762D1385	2C	System	shell32.SHELL32_IconCacheRestore+17E5
0093F318	76334879	76334AB5	34	System	shell32.openas_Rundll+995
0093F34C	762C6CA9	76334879	104	System	shell32.openas_Rundll+759
0093F450	76314B02	762C6CA9	44	System	shell32.ordinal#99+F79
0093F494	763145C7	76314B02	E0	System	shell32.ShellExecuteExW+5D2
0093F574	763FB8B4	763145C7	70	System	shell32.ShellExecuteExW+97
0093F5E4	763FB851	763FB8B4	50	System	shell32.ShellExecuteEx+54
0093F634	04B4B8F7	763FB851	280	User	shell32.ShellExecuteA+61
0093F8B4	04B4F643	04B4B8F7	4C	User	04B4B8F7
0093F900	04A3E202	04B4F643	70	User	04B4F643
0093F970	704C1C27	04A3E202	80	User	04A3E202
0093F9F0	009D4BAA	704C1C27	28	User	log.Logwrite+107

Figura 1.33: Parametri di ShellExecute

Tramite Process Explorer possiamo osservare il processo figlio che viene creato:



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

x32dbg.exe	732 K	90.312 K	3792 x64dbg
BluetoothService.exe	376 K	18.852 K	3020 Bitdefender Submission Wiza... Bitdefender
BluetoothService.exe	388 K	16.484 K	2172 Bitdefender Submission Wiza... Bitdefender
modem.exe	100 K	118.524 K	7412 Microsoft Edge Microsoft Corporation

Figura 1.34: Processo figlio spawnato

3. **Modalità Payload (Parametro **-k**):** Questa modalità salta i controlli preliminari e avvia direttamente la logica malevola finale, decodificando e mandando in esecuzione il codice (Shellcode + comunicazione C2).
- **Creazione Mutex:** Verifica la presenza di un Mutex (es. `Global\Jdhfv_1.0.1`) e in caso contrario lo crea per segnalare la sua singola istanza attiva.

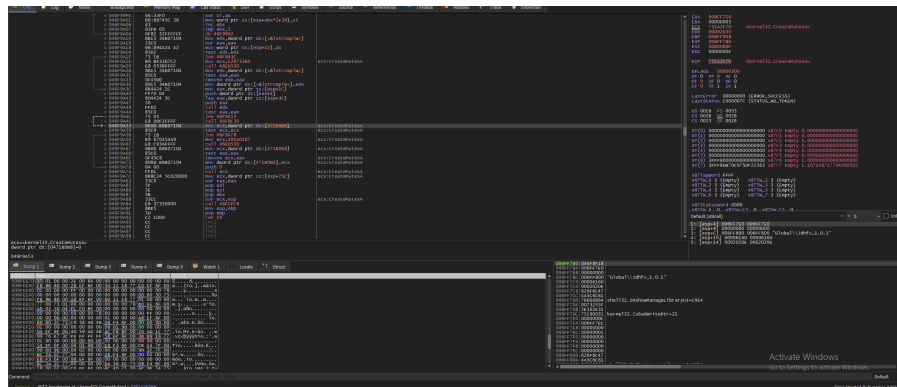


Figura 1.35: Stack per la creazione del Mutex (parte 1)



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

046F8D7B	3202	C885 D5FFFFFF	00	xor ebx,edx	
046F8D7C	B1 47			mov byte ptr ss:[ebp-128],0	
046F8D7D	E8 D542FFFF			mov cl,57	47: 'g'
046F8D7E	BA 01000000			call 46ED040	
046F8D7F	8885 C0FFFFFF			mov edx,1	
046F8D80	B1 6C			mov byte ptr ss:[ebp-140],a1	
046F8D81	E8 C342FFFF			mov cl,6C	6C: 'l'
046F8D82	BA 02000000			call 46ED040	
046F8D83	8885 C1FFFFFF			mov edx,2	
046F8D84	B1 6F			mov byte ptr ss:[ebp-13F],a1	
046F8D85	E8 B142FFFF			mov cl,6F	6F: 'o'
046F8D86	BA 03000000			call 46ED040	
046F8D87	8885 C2FFFFFF			mov edx,3	
046F8D88	B1 62			mov byte ptr ss:[ebp-13E],a1	
046F8D89	E8 9F42FFFF			mov cl,62	62: 'b'
046F8D8A	BA 04000000			call 46ED040	
046F8D8B	8885 C3FFFFFF			mov byte ptr ss:[ebp-13D],a1	
046F8D8C	B1 61			mov cl,61	61: 'a'
046F8D8D	E8 8D42FFFF			call 46ED040	
046F8D8E	BA 05000000			mov edx,5	
046F8D8F	8885 C4FFFFFF			mov byte ptr ss:[ebp-13C],a1	
046F8D90	B1 6C			mov cl,6C	6C: 'l'
046F8D91	E8 7842FFFF			call 46ED040	
046F8D92	BA 06000000			mov edx,6	
046F8D93	8885 C5FFFFFF			mov byte ptr ss:[ebp-13B],a1	
046F8D94	B1 5C			mov cl,5C	5C: '\\'
046F8D95	E8 6942FFFF			call 46ED040	
046F8D96	BA 07000000			mov edx,7	
046F8D97	8885 C6FFFFFF			mov byte ptr ss:[ebp-13A],a1	
046F8D98	B1 4A			mov cl,4A	4A: 'j'
046F8D99	E8 5742FFFF			call 46ED040	
046F8D9A	BA 08000000			mov edx,8	
046F8D9B	8885 C7FFFFFF			mov byte ptr ss:[ebp-139],a1	
046F8D9C	B1 64			mov cl,64	64: 'd'
046F8D9D	E8 4542FFFF			call 46ED040	
046F8D9E	BA 09000000			mov edx,9	09: '\t'
046F8D9F	8885 C8FFFFFF			mov byte ptr ss:[ebp-138],a1	
046F8DA0	B1 68			mov cl,68	68: 'h'
046F8DA1	E8 3342FFFF			call 46ED040	
046F8DA2	BA 0A000000			mov edx,A	0A: '\n'
046F8DA3	8885 C9FFFFFF			mov byte ptr ss:[ebp-137],a1	
046F8DA4	B1 66			mov cl,66	66: 'f'
046F8DA5	E8 2142FFFF			call 46ED040	
046F8DA6	BA 0B000000			mov edx,8	0B: '\\v'
046F8DA7	8885 CAFFFFFFFF			mov byte ptr ss:[ebp-136],a1	
046F8DA8	B1 76			mov cl,76	76: 'v'
046F8DA9	E8 0F42FFFF			call 46ED040	
046F8DAA	BA 0C000000			mov edx,C	0C: '\f'
046F8DAB	8885 CBFFFFFF			mov byte ptr ss:[ebp-135],a1	
046F8DAC	B1 5F			mov cl,5F	5F: '_'
046F8DAD	E8 FD41FFFF			call 46ED040	
046F8DAE	BA 0D000000			mov edx,D	0D: '\r'
046F8DAF	8885 CCFFFFFF			mov byte ptr ss:[ebp-134],a1	
046F8DB0	B1 25			mov cl,25	25: '%'
046F8DB1	E8 E841FFFF			call 46ED040	
046F8DB2	BA 0E000000			mov edx,E	
046F8DB3	8885 CDFFFFFF			mov byte ptr ss:[ebp-133],a1	
046F8DB4	B1 73			mov cl,73	73: 's'
046F8DB5	E8 D941FFFF			call 46ED040	
046F8DB6	8885 CEFFFFFF			mov byte ptr ss:[ebp-132],a1	

Figura 1.36: Stack per la creazione del Mutex (parte 2)

Questo inoltre può essere confermato anche tramite Process Explorer:

Figura 1.37: Visualizzazione Mutex in Process Explorer

- **Info Stealing:** Raccoglie una fingerprint approfondita dell'host, comprendente i dettagli del Sistema Operativo, l'elenco degli Antivirus, l'orario e il Nome Utente/Computer. È inoltre possibile notare che lo stack contiene i vari metodi HTTP delle richieste.



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

```
032FEF58 68 74 74 70 73 3A 2F 2F 61 70 69 2E 73 68 79 63 https://api.skyc
032FEF68 6C 6F 75 64 63 65 6E 74 65 72 2E 63 6F 6D 2F 61 loudcenter.com/a
032FEF78 2F 63 68 61 74 2F 73 2F 37 30 35 32 31 64 64 66 /chat/s/70521ddf
032FEF88 2D 61 32 65 66 2D 34 61 64 66 2D 39 63 66 30 2D -a2ef-4adf-9cf0-
032FEF98 36 64 38 65 32 34 61 61 61 38 32 31 00 00 00 00 6d8e24aaa821....
032FEFA8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FEFB8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FEFC8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FEFD8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FEFE8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FEFF8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF008 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF018 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF028 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF038 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF048 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF058 42 6C 75 65 74 6F 6F 74 68 53 65 72 76 69 63 65 BluetoothService
032FF068 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF078 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF088 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF098 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF0A8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF0B8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF0C8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
032FF0D8 41 63 63 65 70 74 3A 20 2A 2F 2A 0A 55 73 65 72 Accept: */*.User
032FF0E8 2D 41 67 65 6E 74 3A 20 4D 6F 7A 69 6C 6C 61 2F -Agent: Mozilla/
032FF0F8 35 2E 30 20 28 57 69 6E 64 6F 77 73 20 4E 54 20 5.0 (windows NT
032FF108 31 30 2E 30 3B 20 57 69 6E 36 34 3B 20 78 36 34 10.0; win64; x64
032FF118 29 20 41 70 70 6C 65 57 65 62 4B 69 74 2F 35 33 ) AppleWebKit/53
032FF128 37 2E 33 36 20 28 4B 48 54 4D 4C 2C 20 6C 69 6B 7.36 (KHTML, lik
032FF138 65 20 47 65 63 6B 6F 29 20 43 68 72 6F 6D 65 2F e Gecko) Chrome/
032FF148 38 30 2E 30 2E 34 30 34 34 2E 39 32 20 53 61 66 80.0.4044.92 Saf
032FF158 61 72 69 2F 35 33 37 2E 33 36 0A 43 6F 6E 74 65 ari/537.36.Conte
032FF168 6E 74 2D 54 79 70 65 3A 20 74 65 78 74 2F 68 74 nt-Type: text/ht
032FF178 6D 6C 0A 41 63 63 65 70 74 2D 4C 61 6E 67 75 61 ml.Accept-Langua
032FF188 67 65 3A 20 65 6E 2D 55 53 2C 65 6E 3B 71 3D 30 ge: en-US,en;q=0
032FF198 2E 39 00 00 00 00 00 00 00 00 00 00 00 00 00 .9.....
032FF1A8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
```

Figura 1.40: Web Request Header HTTP POST



Supply-Chain Attack against Notepad++: Analysis of Chrysalis

Address	Type	Ordinal	Symbol	Symbol
700FF280	Export	6	winHttpAddRequestHeaders	
70100270	Export	41	winHttpOpenRequest	
70101BF0	Export	46	winHttpQueryOption	
701033A0	Export	50	winHttpReceiveResponse	
70104490	Export	60	winHttpTimeFromSystemTime	
70106470	Export	51	winHttpResetAutoProxy	
701068C0	Export	37	winHttpGetProxyResultEx	
701076F0	Export	61	winHttpTimeToSystemTime	
70107BC0	Export	59	winHttpSetTimeouts	
70112810	Export	40	winHttpOpen	
70112AB0	Export	45	winHttpQueryHeaders	
70113B50	Export	24	winHttpCreateProxyResolver	
70114020	Export	56	winHttpSetOption	
70114300	Export	58	winHttpSetStatusCallback	
70116170	Export	10	winHttpCloseHandle	
70116BA0	Export	33	winHttpGetProxyForUrlEx2	
701172A0	Export	11	winHttpConnect	
70118090	Export	53	winHttpSendRequest	
70118640	Export	32	winHttpGetProxyForUrl	
70118940	Export	44	winHttpQueryDataAvailable	
7011CD70	Export	25	winHttpCreateUrl	
7011D300	Export	23	winHttpCrackUrl	
7011F090	Export	30	winHttpGetDefaultProxyConfiguration	
70121790	Export	28	winHttpFreeProxyResultEx	
70128220	Export	47	winHttpReadData	
7012D130	Export	48	winHttpReadProxySettings	
7012D890	Export	31	winHttpGetIEProxyConfigForCurrentUser	
7012DB60	Export	38	winHttpGetProxySettingsVersion	
70138150	Export	68	winHttpWriteData	
7013ADF0	Export	22	winHttpConnectionUpdateIfIndexTable	
7013B3E0	Export	8	winHttpAutoProxySvcMain	
7013DC70	Export	20	winHttpConnectionSetPolicyEntries	
7013DE10	Export	12	winHttpConnectionDeletePolicyEntries	
7013E570	Export	5	SvchostPushServiceGlobals	
7013EBA0	Export	0	OptionalHeader.AddressOfEntryPoint	
7013F5F0	Export	2	DllCanUnloadNow	
7013F5F0	Export	9	winHttpCheckPlatform	
701401B0	Export	57	winHttpSetProxySettingsPerUser	
701637C0	Export	3	DllGetClassObject	
70163C30	Export	4	Private1	
70163EA0	Export	7	winHttpAddRequestHeadersEx	
70165550	Export	42	winHttpProbeConnectivity	
701655E0	Export	52	winHttpSaveProxyCredentials	
70167F40	Export	1	winHttpPacJsWorkerMain	
70168050	Export	26	winHttpDetectAutoProxyConfigUrl	
70168240	Export	27	winHttpFreeProxyResult	
701682A0	Export	29	winHttpFreeProxySettings	
70168350	Export	34	winHttpGetProxyForUrlEx	
70168430	Export	35	winHttpGetProxyForUrlHvsi	
701684D0	Export	36	winHttpGetProxyResult	
701684F0	Export	49	winHttpReadProxySettingsHvsi	

Figura 1.41: Librerie HTTP Caricate

Tramite questo canale interattivo su protocollo POST, la backdoor Chrysalis può ricevere ed eseguire autonomamente una suite di 16 diverse istruzioni (upload, download, proxy e spawn di processi), confermandosi uno strumento altamente modulare ed evasivo per il toolkit Lotus Blossom.